

Towards Integrated Quantitative Security and Safety Risk Assessment*

Jürgen Dobaj¹[0000–0001–6460–8080], Christoph Schmittner²[0000–0003–4430–6813],
Michael Krisper¹[0000–0001–9824–3585], and Georg Macher¹[0000–0003–2179–3946]

¹ Graz University of Technology, Graz 8010, Austria
{juergen.dobaj, michael.krisper, georg.macher}@tugraz.at
² AIT Austrian Institute of Technology, Vienna 1020, Austria
christoph.schmittner@ait.ac.at

Abstract. Although multiple approaches for the combination of safety and security analysis exist, there are still some major gaps to overcome before they can be used for combined risk management. This paper presents the existing gaps, based on an overview of available methods, which is followed by the proposal towards a solution to achieve coordinated risk management by applying a quantitative security risk assessment methodology. This methodology extends established safety and security risk analysis methods with an integrated model, denoting the relationship between adversary and victim, including the used capabilities and infrastructure. This model is used to estimate the resistance strength and threat capabilities, to determine attack probabilities and security risks.

Keywords: security analysis, safety analysis, risk assessment, threat analysis, threat modeling, SAHARA, FMVEA, Diamond, FAIR

1 Introduction

Formerly, security played only a secondary role in safety- and mission-critical systems, since these systems were not connected to the Internet or the outer world. However, with the introduction of Internet-of-Things (IoT) and cyber-physical system (CPS) concepts into multiple industrial domains, the industry is undergoing enormous change towards highly interconnected and globally distributed automation and control systems, ranging from intelligent transportation systems [5] and industrial systems [27], to smart homes and smart cities [4]. Security mechanisms are responsible for protecting these systems from unwanted access or malicious attacks. Therefore, system security becomes an essential factor affecting the safety of mission-critical systems. Consequently, this requires an holistic dependability engineering approach integrating both, security and safety.

In particular, dependability is defined by multiple attributes (availability, reliability, safety, confidentiality, integrity, maintainability) that must be maintained and assured at a sufficient level. This is commonly achieved by considering

*This is a pre-print version. The final authenticated version is available online at https://doi.org/10.1007/978-3-030-26250-1_8.

the risk of potential threats (faults, errors, failures), followed by applying adequate risk reduction mechanisms (fault prevention, fault tolerance, fault removal, fault forecasting). It should be noted, that the term fault is quite generic, ranging from systematic weaknesses in software to insufficiently designed hardware.

Risk reduction denotes the effort to deliberately reduce risks to a tolerable level, instead of fantasizing about reducing all risks to zero, which makes it inevitable to prioritize risks and risk treatments. Risk treatment is defined as a cyclic process [10] of: 1.) assessing existing risk treatments; 2.) deciding if the residual risks are tolerable; 3.) generating new risk treatments, if not tolerable; and again 4.) assessing the new risk treatments. There are multiple risk treatments available, however, in dependable systems it is often required to implement specific measures for achieving a tolerable risk level. Therefore, decisions about risk treatments directly influence system engineering, requiring an evaluation of where engineering resources should be dedicated. Risk is generally defined by the likelihood and impact of a loss event classified according to only partially comparable categories (e.g. safety, financial, operational, privacy/confidentiality, ...). For example, functional safety considers safety impacts based on faults, errors, and failures of electric/electronic/programmable electronic (E/E/PE) elements. As long as risks compare similar categories, a similar likelihood scale can be used, which enables decisions on the required risk reduction mechanisms. However, different categories should not be mixed up, like financial loss and harm to human lives should be considered separately.

In the context of connected systems, it is essential to not only consider safety risks, but also security risks originating from malicious manipulations by e.g., internal or external actors. Such manipulations might have an impact on the same dependability attribute, but the resulting failure may be differently categorized, making it difficult to prioritize the risk treatments accordingly. Hence, there is and will be an ever increasing need to coordinate between the engineering processes that focus on different dependability attributes in system engineering [18]. This coordination requires combined methods as well as a common language for communicating and comparing risks. Whoever decides on the treatment of risks, should therefore, be provided with risk ratings in comparable scales.

In contrast to the statistical failure probability concept known from the safety domain, system security does not exclusively depend on statistical information about vulnerabilities and weaknesses, instead it is mainly driven by the interaction of an (human or machine) attacker against the resistance of a system. Integrating such human aspirations and motivations for mischief or selfish advantage into a likelihood system for risk is difficult, therefore imposing significant restricts to both, the coordination of security with safety risks, as well as with all other dependability attributes. While there are methods for combined considerations [16], they are still lacking some of the properties needed for a full risk analysis, meaning identification and evaluation, which was a major finding of this paper and gives us open challenges to resolve, for protecting safety critical systems against malicious attacks [14].

In the course of this document, a discussion of related work and state-of-the-art analysis methods is provided in Section 2, which we expand by a brief discussion of the methods actual limitations to enable combined security and safety risk assessment. In Section 3, we introduce a new model for assessing the probability of security attacks in dependable CPSs. Therefore, we propose an approach that is based on established methods for combined considerations of

safety and security features, which is accomplished by an established method for security incident analysis. This model is then used in Section 3.2 as qualified information framework to quantitatively classify the probability of cybersecurity attacks, by adapting and extending an established method for IT-security risk assessment. Section 3.3 presents an illustrative example, followed by an outlook and a closing discussion in Section 4.

2 Background

In this section an overview of relevant standards and context of related work is given. To that aim, also the differences of cyber-security and safety, as well as the applied integrated methods are briefly described. Additionally, as first contribution of this work, a comparison between established integrated risk assessment methods is given in Section 2.3.

2.1 Safety vs. Security

The idea of safety and security co-design has become a major trend of recent publications and is expected to appear more often in the future, also due to the upcoming security standards for safety critical domains, and the requirements on communication and coordination between safety and security. However, one of the main challenges of this merging of safety and security disciplines is the different level of maturity in the standards and the available knowledge in the domains. Safety, as well as security engineering focus on system-wide features and need to be integrated adequately into the existing process landscape; both having a major impact on product development and product release, as well as for company brand.

Therefore, a tight integration and cooperation between these two domains seems obvious and essential. The difference between safety and security, and one of the major show stoppers, is the very different point-of-view and the fundamentally different engineering approaches and nomenclatures. This issue has already been partially described and tackled in [18].

Beside this, functional safety engineering approaches focus on defects, failures, and errors, which can be foreseen (with reservations) at design-time, as well as on mathematical models based on failure probabilities and system models. Therefore, functional safety standards are defining domain specific processes and methods for the development of safety-critical embedded systems. They target the minimization of systematic failures during development (e.g., requirement not implemented in the development phase) as well as the control of random failures during operation (e.g., component break-down). These standards rely on efficient quality management in project, and systematic hazard identification and management along the entire development life-cycle. Sound technical concept and validation planning, as well as trace management between these different items is a central aspect for safety augmentations.

On the contrary, security standards often just provide a set of high-level guiding principles for the life-cycle process framework, some basic guiding principles on cyber-security, or focus on a subset of the complete engineering process; but there are no common base practices or methodologies which are shared. Common Criteria [13], for example, is a detailed standard for security evaluation, but not applicable to security engineering.

Safety and security features have mutual impacts, sometimes similarities, and interdisciplinary values in common. However, these different attributes might

lead to different targets, and mutual impact between safety and security exist. This even goes as far, that safety and security features frequently appear to be in total contradiction to the overall system features. A straight forward example of this contradiction can be shown by an electrical steering column lock system. In the security context, the system locks the steering column when in doubt, because this doubt area might result from an attack. From the safety perspective, however, it is highly undesirable to lock the steering column. Since, the issue involved might well be an occurrence directly before a high speed corner turn and would leave the driver without control over the steering wheel.

In addition to that, using non-integrated methods to manage these different attributes might lead to inconsistencies, which are identified in late development phases. Therefore, a solid information handover and a cooperative dependability engineering by cross-domain expert teams are required [16].

2.2 Qualitative vs. Quantitative Methods

Many established methods use qualitative assessments based on ordinal scales e.g. rating the severity of a safety hazard on a scale between 0 and 3, or rating the threat level of a security threat on a scale from “no security impact” to “moderate relevance” and “high security and possible safety relevance”. Typically these ratings consist of 2 to 3 ordinal scales which get combined either by addition or multiplication to obtain a final risk rating based on thresholds. Such qualitative assessments methods based on ordinal scales and so called “risk matrices” have several shortcomings including e.g., range compression / poor resolution, risk inversion, ambiguity, and neglecting correlations, which is shown in several publications by Hubbard et al. [8,7], and Cox et al. [2,3].

To avoid such pitfalls, we propose to apply a fully quantitative assessment method like factor analysis of information risk (FAIR), which is based upon the estimation of event frequencies, system vulnerabilities, and event impacts using probability distributions that enable to also take the respective uncertainty (or confidence - as it is called in the diamond model) of an estimation into account.

2.3 Comparison of Established Integrated Risk Assessment Methods

As already mentioned, risk management is an essential step in the development of critical systems. On a domain-independent level, risk management is defined by ISO 31000 [10]. For ISO and IEC standards the ISO/IEC Directives, Part 1 [12] requires all product or industry/economic sector specific risk management standards to reference or reproduce ISO 31000. ISO 31000 mentions quantitative and qualitative risk analysis and states that specific results should be consistent and comparable for effective risk management, e.g., all risks in comparable scales. Outside of ISO and IEC standards, there is also work on risk management. national institute of standards and technology (NIST), for example, published in 2012 *NIST Special Publication 800-30 (SP800-30) Guide for Conducting Risk Assessments* [15], for guidance in conducting risk assessments on federal information systems and organizations. SP800-30 also refers to the ISO 31000 risk management standards. In its main part, quantitative, qualitative and semi-quantitative approaches are discussed. In its annex a potential approach similar to FAIR is presented, where the likelihood of an event is divided into (a) a likelihood, that an adversary is initiating a threat event; and (b) a

likelihood, that the threat event results in an adverse impact (i.e., a successful attack). Semi-quantitative values are given, and NIST SP800-30 warns that it can be challenging to assign a likelihood to a particular bin (e.g., 0-15, 16-35, 36-70), especially if it is between two levels.

In recent work [17], Macher et al., focused on enhancing the development lifecycle for automotive CPS by analyzing state-of-the-art methods for integrated security, safety, and reliability engineering. Their finally proposed framework is based on security-aware hazard and risk analysis (SAHARA), failure mode, vulnerabilities and effects analysis (FMVEA), and attack tree analysis (ATA), representing a promising approach for the integrated design of safe and secure systems in the automotive domain, which is the reason why we use them in our approach too. A comprehensive overview and comparison of related methods can be found in [16].

While SAHARA and FMVEA have its origin in the automotive sector, our proposed integrated risk management approach is not restricted to a specific domain. Instead, it supports the general level of ISO 31000 and allows to manage uncertainty and missing information in a risk management process.

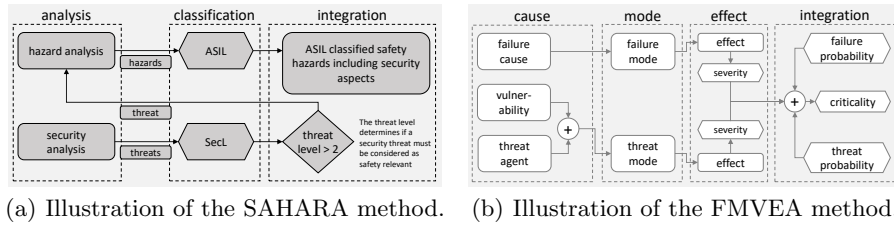


Fig. 1. Overview of the approaches for integrated risk assessment methods.

The SAHARA method, illustrated in Figure 1(a), depicts a systematic approach to quantify the security impact on dependable safety-related systems on system level [19]. Therefore, the method combines the automotive hazard analysis and risk assessment (HARA) [11] approach with STRIDE [21] threat modelling.

The FMVEA method, illustrated in Figure 1(b), is based on the failure mode and effects analysis (FMEA) as described in IEC 60812 [9] with additional support for security analysis, also based on the STRIDE threat modelling approach [22]. FMVEA uses a threat&failure-mode-effect model for its safety and security risk analysis targeted towards the item level.

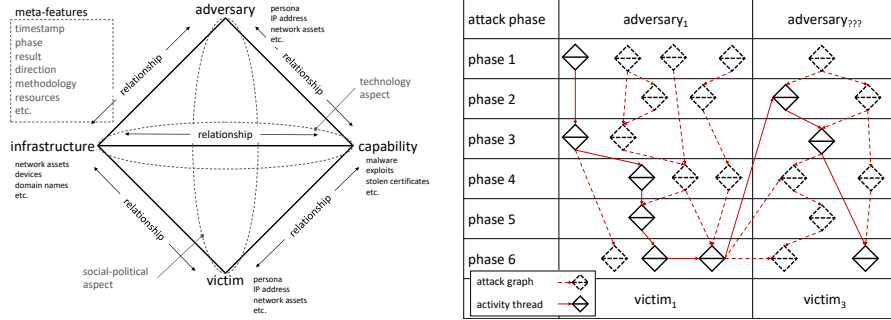
Integrated risk assessment. Both methods, SAHARA and FMVEA, describe integrated approaches that extend established safety risk analysis methods to not only classify the risk of system failures, but also the risk of security threats. For this cybersecurity risk classification the methods define schemes similar to those known from safety engineering. However, instead of finding and rating potential system failures and failure causes, cybersecurity risk assessment is targeted towards identifying and rating potential vulnerabilities and threats and the interplay of both with assumed attackers. Therefore, the methods provide rating schemes to assess (i) the attacker strength, denoted by the attacker capabilities, intention, and know-how; (ii) the system resistance, partially denoted by static

security measures classified by the system reachability, structure, and required attack tools; and (iii) the impact of a successful attack, denoted by the effects on the system and its environment.

The attacker strength and the system resistance are combined to estimate the probability of a potentially successful attack. The attack probability and impact determine the criticality level of a security threat, which is also used to indicate the safety relevance of a security threat. Beside the criticality level, the SAHARA method also specifies a so called security level (SecL) to provide guidance in selecting the appropriate number of countermeasures that should be considered [19]. The FMVEA, on the other hand, uses the resulting risk priority number (RPN) as a comparable indicator to focus the development efforts on the most critical issues and system areas [22].

For determining the SecL and RPN, both methods rely on qualitative measures. However, qualitative measures are not suitable for mathematical models to calculate the overall vulnerability of the system. Moreover, the measures lack calibration with the failure probability to enable a integrated combined safety and security risk management [22]. Another, general limitation of both methods is the restriction to analyze only single causes of an effect [22]. Hence, multi-stage attacks could be overlooked, which, however, would be of particular relevance for analyzing security attacks.

2.4 The Diamond Model of Intrusion Analysis



(a) Illustration of the diamond model of intrusion analysis (adapted from [1]). (b) Illustration of activity threats and attack graphs (adapted from [1]).

Fig. 2. Excerpt of the diamond modelling capabilities.

The *diamond model of intrusion analysis* [1] is an established formal method to analyze cyber-incidents after their occurrence. Figure 2(a) illustrates a diamond that represents a basic atomic element of any intrusion activity, also denoted as (security) event. The key assumption of the diamond model is that “for every intrusion event there exists an **adversary** taking a step towards an intended goal by using a **capability** over **infrastructure** against a **victim** to produce a result” [1]. Hence, an event is composed of four core-features (described later in Section 3.1): adversary, capability, infrastructure, and victim. These features are arranged in the shape of a diamond, where the edges represent the underlying relationships between the features. The diamond further defines meta-features to support higher-level constructs, which includes linking multiple events to form activity threads and attack graphs. These threads and

graphs are illustrated in Figure 2(b). Activity threads and attack graphs are comparable to attack trees [23]. An **activity thread** consists of a set of diamonds representing an attack path through the graph. An **attack graph** enumerates multiple paths an adversary could have taken in the attack, while an activity thread represents an already identified attack path.

After the detection of an incident, there is generally limited information about the attack sequence and exploited vulnerabilities available. Thus, the major idea of the diamond model is that the events, threads, and graphs form a documentation and information framework that facilitates the structured analysis of such incidents. This helps analysts to ask the right questions to uncover missing links, vulnerabilities, and the actual adversary. By assigning confidence values to both, core- and meta-features, the confidence into the actual analysis is documented.

2.5 The FAIR Method for Risk Analysis

The FAIR method is a way of determining the risk of an attack event [25]. It is based on splitting risk into several sub-factors to more easily evaluate IT-security and operational risk [6,25,26], as shown in Figure 3(a). These sub-factors are rated in the form of expert judgements by describing the minimum, maximum, and most likely value including a confidence rating. The judgements, as shown in Figure 3(b) and Figure 3(c), are modelled as program evaluation and review technique (PERT) probability distributions, which originates in project management and was first used by the US Navy to estimate time plans for missions [20].

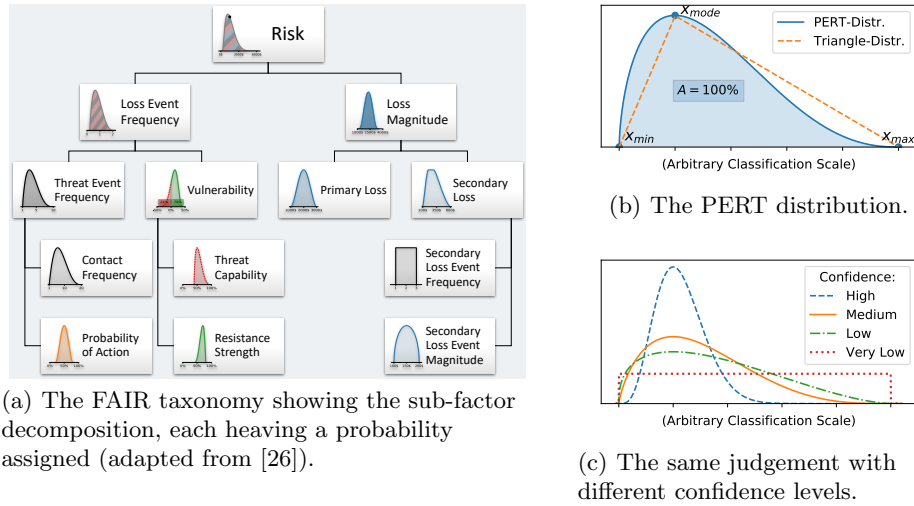


Fig. 3. Overview of the FAIR taxonomy and the PERT distribution.

3 Contribution: Towards a Quantitative Integrated Risk Assessment Method

In the preceding sections we compared the SAHARA [19] and FMVEA [22] methods for integrated risk assessment in CPS. Subsequently, the diamond model [1]

and the FAIR method [25] are introduced to now propose an integrated quantitative risk assessment model that maps features, described by SAHARA and FMVEA, into the diamond model. We propose a methodology for quantitative security risk assessment by combining all these methods, which enables the analysis of security and failure event chains, as well as a coordinated risk management. Therefore, we are using a combined terminology from both, Diamond and FAIR.

3.1 Combining SAHARA, FMVEA, and Diamond into One Model

As already discussed in the previous sections, there exists potential for improving the established integrated risk analysis methods. Since, the diamond model describes a structured model and process for cyber incidents analysis, we propose that the model is capable to complement the integrated methods enabling a more comprehensive risk analysis.

The key assumption of the diamond model is that *“for every intrusion event there exists an adversary taking a step towards an intended goal by using a capability over infrastructure against a victim to produce a result”* [1]. Such an event is modeled by four core-features: (i) the adversary, (ii) the capability, (iii) the infrastructure, and (iv) the victim; as well as arbitrary definable meta-features. We use this meta-features to map the SAHARA and FMVEA attributes and classifiers into the diamond model, which is shown in Figure 4. The boxes represent SAHARA and FMVEA attributes, which are rated by the classifiers illustrated as hexagons.

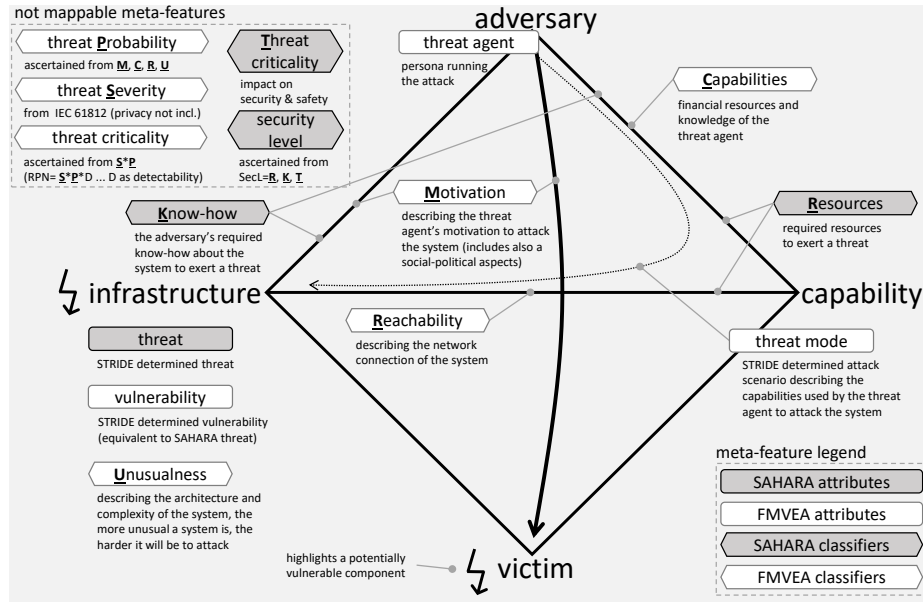


Fig. 4. Illustration of the diamond model including the mapping of the security attributes and their classifiers described by SAHARA and FMVEA.

(i) **The adversary feature** describes a set of adversaries (e.g., in/outside, individuals, groups, and organizations) which seek to compromise a system to

satisfy their intent and needs. An adversary could be described by (a) an adversary operator, the person conducting the intrusion activity; and (b) an adversary customer, the entity that benefits from the conducted activity and generally acts as the funding entity, but might be the same person as the operator [1].

The SAHARA method does not explicitly describe or classify an adversary, however, the adversary is implicitly described by its KNOW-HOW and the RESOURCE classifiers. The KNOW-HOW classifier determines the knowledge and insight an adversary requires to attack the infrastructure, distinguishing between black-, grey-, and white-box views. The method further names adversary examples (e.g., average driver, electrician, mechanic, ...) for each of the views imposing capabilities on the adversary. Hence, KNOW-HOW is mapped onto two edges describing both, the *adversary – infrastructure* and the *adversary – capability* relationship. The RESOURCE classifier determines the required resources an adversary must possess to attack the infrastructure, ranging from no tool support to advanced tool support. The RESOURCE classifier is mapped onto the *adversary – capability* relationship describing the tools required to deliver an attack over infrastructure, described by the *capability – infrastructure* relationship.

In contrast, the FMVEA method explicitly states the adversary as threat agent classified according to ISO 27005 [24] making the mapping obvious. The ISO 27005 classification also characterizes the adversaries CAPABILITIES described by its financial resources and knowledge. FMVEA refines this by its MOTIVATION classifier, which takes both, technical and social-political aspects into account, described by the *adversary – infrastructure* and *adversary – victim* relationships.

(ii) **The capability feature** captures the tools and techniques an adversary used within a diamond event. This can be divided into (a) the capability capacity, all vulnerabilities and exposures of the target system that could potentially be utilized by the adversary; and (b) the capability arsenal, the actual set of the adversary’s capability. The capacity is used to also document non-exploited vulnerabilities providing input for potential system improvements [1].

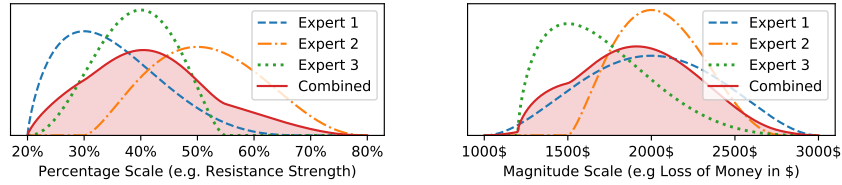
(iii) **The infrastructure feature** describes physical and/or logical communication structures that are used by the adversary to deliver a capability, maintain control of capabilities, and effect results on the victim. The infrastructure feature is divided into three types: (a) type 1 infrastructure, is fully controlled or owned by the adversary or which they may be in physical proximity; (b) type 2 infrastructure, is controlled by an (witting or unwitting) intermediary, which is typically the infrastructure an adversary uses to obfuscate its actions; (c) service providers, are organizations that (witting or unwitting) provide services critical for availability of type 1 and type 2 infrastructure [1].

Both, SAHARA and FMVEA, are based on the STRIDE [21] threat modelling approach to identify and categorize potential THREATS and VULNERABILITIES of the infrastructure. The FMVEA method uses this categorization to describe and identify potential THREAT MODES specifying the manner in which security fails, which is similar to the failure modes of safety. In terms of the diamond model a THREAT MODE can be described as the resources and infrastructure used by the adversary to deliver its capabilities, represented as the *adversary – capability – infrastructure* relationship.

(iv) **The victim feature** describes the target of the adversary and against whom vulnerabilities and exposures are exploited and capabilities used. It is useful to divide the victim assets into (a) victim persona, the people and organizations targeted whose assets are exploited and attacked; and into (b) victim assets, the attack surface consisting of networks, systems, hosts, etc. against which the adversary directs their capabilities. It should be considered that in multi-stage attacks a victim asset, can be the end target in one event and then leveraged as the infrastructure in further events. Thus, one must always be aware that the target of an activity may not necessarily be the victim. Further, the victim assets often exist both, inside and outside a persona’s control or visibility. However, still available for targeting by an adversary, which commonly includes cloud-based data storage and applications [1].

3.2 Extending FAIR for Risk Analysis Based on Diamond Events

After mapping the attributes from SAHARA and FMVEA to the diamond model, we have a qualified information basis for estimating the actual probability, severity and risk of a diamond event. For this estimation we apply and extend the FAIR method to give consolidated and refined expert judgements of the resulting risk within a diamond event. We implemented this in a mathematical framework to combine and propagate probabilities for quantitative security and safety risk analysis, providing the basis for future applications.



(a) Multiple expert judgements of probability values for resistance strength are combined into a mixture distribution. (b) Multiple expert judgements for magnitude of impact (in this case: the loss of money) are combined.

Fig. 5. Combination of multiple expert judgements shown for different scales of value ranges. The area under the distribution is always normalized to 100%.

Combining Multiple Expert Judgements. We refined the FAIR method by combining multiple expert judgements to obtain a more realistic probability space for the respective value distribution. The resulting mixture probability distribution supports multiple centers of mass, better reflecting the given judgements, and also supporting differing confidence levels between single judgements. Figure 5(a) and Figure 5(b) show examples of such mixture distributions from multiple experts. It is possible to mix different distribution types within the mixture model, so we are not limited to PERT distributions only.

3.3 Discussion of Enhancements and Open Issues

This section provides an illustrative example, shown in Figure 6, that summarizes and critically discusses the proposed approach. Like most integrated methods, as outlined in Section 2, SAHARA and FMVEA are based on threat modelling to identify potential security risks. Both, SAHARA and FMVEA, use the STRIDE

threat modelling approach [21] as starting point for their security analysis, as indicated on the top-left corner in Figure 6. Our approach utilizes the diamond attack graphs to model and document the identified threats and attack scenarios recognized by applying the STRIDE approach. The obtained attack graphs have the advantage, that the analysis of attack event chains is supported, similar to attack trees [23]. Moreover, their meta-feature concept makes attack graphs more generic, allowing to easily extend the model with additional information, including trace links to requirements, and implementations, as well as capturing and classifying other dependability attributes, like safety. Furthermore, the diamonds

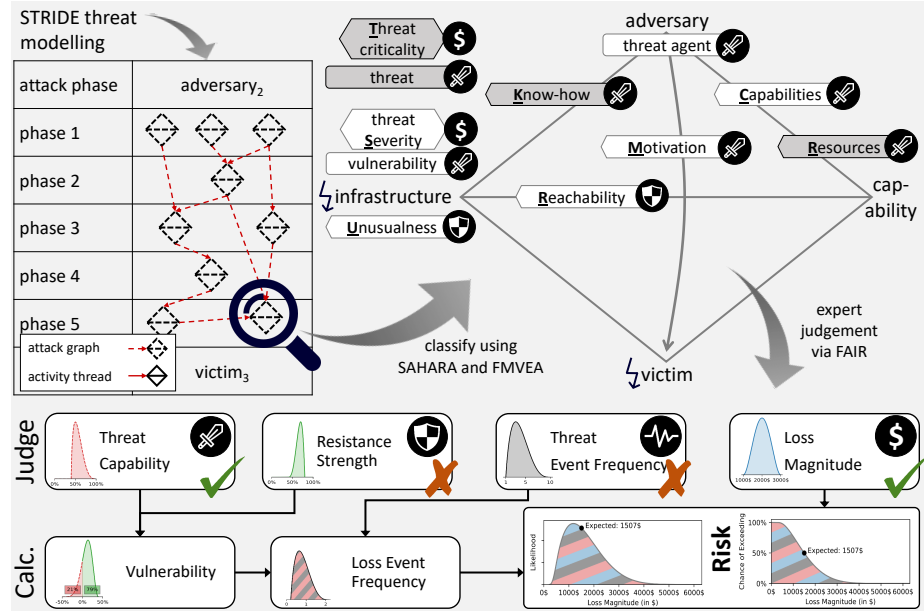


Fig. 6. Illustrative example showing the transition from FMVEA and SAHARA to the Diamond model and evaluating the risk with FAIR. The check-marks indicate, if additional classifiers or information is required to obtain profound expert judgements.

emphasize the technical and social-political relationships between adversary and victim, which supports analysts and designers in identifying otherwise not found vulnerabilities and threats, as well as missing information. This observation is illustrated by the SAHARA and FMVEA classifier mapping, which mainly describe the upper diamond half characterizing the system **threat capability** for the FAIR judgement. The lower diamond half, reflecting the victim and its defense capability, is only partially described by the reachability and unusualness classifiers, representing static security measures only. To better estimate the system **resistance strength**, the proposed model needs to be extended to provide additional classifiers, also covering active security measures that deter, detect, report, and react against threats.

Actually, none of the methods (i.e., SAHARA, FMVEA, FAIR) supports estimating the **threat event frequency**, since only the probability of the single first attack is rated, and no potentially subsequent attacks (by different adversaries) are considered. While this is aligned with the idea of "failure" in the sense

of safety, it is insufficient for analyzing security risks, due to fact that an attack could occur multiple times by multiple attackers without necessarily resulting in faults or failures.

The threat criticality ensures that safety relevant threats are handed over to safety management, and together with the threat severity, they already provide a good basis for estimating the **loss magnitude** of a diamond event.

In short, the proposed method provides the basic premises to integrate/combine security and safety risk assessment by providing means for an integrated quantification approach and a holistic model supporting both, threat and mitigation modelling.

4 Conclusion and Future Work

The primary contribution of this paper is the the definition of a method for integrating security into a combined risk assessment model. To obtain this model we mapped the classifiers described by two integrated risk analysis methods from the automotive domain (i.e., SAHARA and FMVEA), into the diamond model that has its origin in the field of security incident analysis. The obtained mapping reveals that the risk analysis methods do not consider all potentially relevant aspects that are studied in security incident analysis, which clearly encourages the usefulness of a combined model, which can serve as a comprehensive and qualified information basis for evaluating and documenting the actual probability, severity and criticality of security risks.

The mapping further reveals the lack of victim and mitigation strategy models, which are required to estimate the system resistance strength against potential cyber-attacks. Therefore, we encourage the development of a combined method that considers both, threat modelling and mitigation modelling. While *threat modelling* exclusively focuses on the adversary *threat capabilities*, a so called *mitigation model* would also provide a profound basis for judging the system *resistance strength*. Another strong reason for mitigation models is, that system security does not exclusively depend on the existence of vulnerabilities and weaknesses, instead it is mainly driven by the interaction of a human or machine attacker against the resistance of a system. By allowing to also cover the victim assets and deployed mitigation mechanisms, the model proposed in this work, allows estimating the system resistance strength too. However, the proposed model must still be enhance to capture both, passive (already covered) as well as active security measures allowing to deter, detect, report, and react against threats.

Since we are aiming towards a quantitative risk assessment, the model proposed in this work uses the established FAIR method for risk estimation. However, we propose to extend the FAIR method to be applicable on whole attack graphs, instead of single events only, which we are planning to model by an attacker evolving after each successful attack. To finally obtain a model that covers the whole system lifecycle, we are planning to introduce a time based risk prediction model to capture the evolution of attacker capabilities and the system resistance decay over time.

References

1. Caltagirone, S., Pendergast, A., Betz, C.: The diamond model of intrusion analysis. Tech. rep., Center for Cyber Intelligence Analysis and Threat Research Hanover

- MD (2013)
2. Cox, A.L.: What's Wrong with Risk Matrices? *Risk Analysis* **28**(2), 497–512 (Apr 2008). <https://doi.org/10.1111/j.1539-6924.2008.01030.x>
 3. Cox, L.A.: Some Limitations of Risk = Threat Vulnerability Consequence for Risk Analysis of Terrorist Attacks. *Risk Analysis* **28**(6), 1749–1761 (Dec 2008)
 4. Elmaghrawy, A.S., Losavio, M.M.: Cyber security challenges in smart cities: Safety, security and privacy. *Journal of advanced research* **5**(4), 491–497 (2014)
 5. European Commission: A European strategy on Cooperative Intelligent Transport Systems, a milestone towards cooperative, connected and automated mobility. Tech. rep., European Commission (Nov 2016)
 6. Freund, J.: Measuring and managing information risk: a FAIR approach. Butterworth-Heinemann (2015)
 7. Hubbard, D., Evans, D.: Problems with scoring methods and ordinal scales in risk assessment. *IBM Journal of Research and Development* **54**(3) (May 2010)
 8. Hubbard, D.W., Seiersen, R.: How to measure anything in cybersecurity risk. Wiley (2016)
 9. IEC: IEC 60812: Analysis techniques for system reliability - Procedure for failure mode and effects analysis (FMEA) (2006)
 10. ISO: ISO 31000 - risk management - guidelines.
 11. ISO: ISO 26262 Road vehicles - Functional safety (2011)
 12. ISO/IEC: ISO/IEC directives, part 1
 13. ISO/IEC: ISO/IEC 15408: Information Technology Security Evaluation (2005)
 14. Johnson, C.W.: Why we cannot (yet) ensure the cybersecurity of safety-critical systems. In: *Proceed. 24th Safety-Critical Systems Symposium*. pp. 171–182 (2016)
 15. Joint Task Force Transformation Initiative: Guide for conducting risk assessments. <https://doi.org/10.6028/NIST.SP.800-30r1>
 16. Lisova, E., Sljivo, I., Causevic, A.: Safety and security co-analyses: A systematic literature review (2018)
 17. Macher, G., Armengaud, E., Kreiner, C., Brenner, E., Schmittner, C., Ma, Z., Martin, H., Krammer, M.: Integration of Security in the Development Lifecycle of Dependable Automotive CPS (2017)
 18. Macher, G., Hoeller, A., Sporer, H., Armengaud, E., Kreiner, C.: A Comprehensive Safety, Security, and Serviceability Assessment Method. In: *Computer Safety, Reliability, and Security - 34th International Conference, SAFECOMP 2015* (2015)
 19. Macher, G., Sporer, H., Berlach, R., Armengaud, E., Kreiner, C.: SAHARA: A Security-Aware Hazard and Risk Analysis Method. In: *Design, Automation & Test in Europe Conference & Exhibition* (year), 2015 (2015)
 20. Malcolm, D.G., Roseboom, J.H., Clark, C.E., Fazar, W.: Application for a technique for research and development program evaluation (1959)
 21. Microsoft Corporation: The STRIDE Threat Model (2005), <http://msdn.microsoft.com/en-us/library/ee823878%28v=cs.20%29.aspx>
 22. Schmittner, C., Gruber, T., Puschner, P., Schoitsch, E.: Security Application of Failure Mode and Effect Analysis (FMEA). In: *33rd International Conference, SAFECOMP 2014*, pp. 310–325. Springer, Cham (2014)
 23. Schneier, B.: Attack Trees (1999), <http://www.schneier.com/attacktrees.pdf>
 24. International Organization for Standardization (ISO), I.E.C.I.: Information technology Security techniques Information security risk management (2008)
 25. The Open Group: Risk Analysis (O-RA) (Oct 2013)
 26. The Open Group: Risk Taxonomy (O-RT) 2.0 (Oct 2013)
 27. Xu, L.D., Xu, E.L., Li, L.: Industry 4.0: state of the art and future trends. *International Journal of Production Research* **56**(8), 2941–2962 (2018)